

THEMISIQ

Platform System Manual

Features · Database Architecture · Cross-Module Integration Guide

ARIA GRID BCM SENTINEL ERM ORM

Platform Modules

ThemisIQ is composed of six specialist compliance modules, each with its own database, theme, and feature set — unified under a single platform.

ARIA — Governance, Risk & Compliance

Framework management, control mapping, policy generation and risk register

Features

- Import & manage compliance frameworks (ISO 27001, SOC 2, GDPR, NIST CSF, etc.)
- Cross-map controls across multiple frameworks simultaneously
- AI-assisted policy generation (Claude API) from control requirements
- Evidence and document attachment to controls
- Risk register with likelihood × impact scoring
- "Ask ARIA" — RAG semantic search over policy and control text
- Compliance mapping visualisation across frameworks
- Control re-evaluation triggers from GRID audit findings

Events emitted: `aria.policy.published` `aria.policy.updated` `aria.risk.created` `aria.risk.escalated`
`aria.control.updated`

Database tables: `aria_frameworks` `aria_controls` `aria_control_mappings` `aria_policies` `aria_risks` `aria_documents`
`aria_evidence` `aria_ask_index` (FTS5)

GRID — Audit Management

Audit scheduling, evidence capture, non-conformance tracking and compliance scoring

Features

- Audit scheduling and control sampling
- Evidence capture with file upload and versioning
- Non-conformance (NC) tracking and gap analysis
- Compliance scoring cached per audit and framework
- PDF & DOCX branded audit report generation
- Cross-module vendor profile integration
- Audit timeline, reminders and approval workflows

- AI-assisted finding write-up
- Background scheduler for escalations and weekly backups
- Post-incident audit creation on Sentinel breach confirmation

Events emitted: `grid.audit.completed` `grid.finding.created` `grid.non_conformance.raised` `grid.policy.requested` `vendor.created`

Database tables: `grid_audits` `grid_controls` `grid_evidence_items` `grid_evidence_files` `grid_findings` `grid_non_conformances` `grid_vendors` `grid_compliance_scores` `grid_timeline` `grid_reports` `grid_reminders` `grid_approval_requests`

BCM — Business Continuity Management

BIA, continuity plans, incident management and vendor dependency mapping

Features

- Business Impact Analysis (BIA) with criticality scoring
- Continuity plan creation, approval and activation workflow
- Live incident management with real-time chat console
- Incident exercises and training programme tracking
- Vendor and business dependency mapping
- Scheduled plan review reminders
- AI-assisted continuity plan generation
- Auto-escalates to Sentinel on SEV-1/2 incidents

Events emitted: `bcm.incident.declared` `bcm.incident.resolved` `bcm.risk.escalated` `bcm.plan.approved` `bcm.plan.activated` `vendor.created`

Database tables: `bcm_bia` `bcm_risks` `bcm_plans` `bcm_incidents` `bcm_incident_chat` `bcm_incident_updates` `bcm_exercises` `bcm_training` `bcm_vendors` `bcm_dependencies` `bcm_plan_reviews` `bcm_documents`

Sentinel — Data Protection & Privacy

RoPA, DPIA, breach notification, DSR management across 27 jurisdictions

Features

- Record of Processing Activity (RoPA) management
- Data Protection Impact Assessment (DPIA) workflow
- Breach notification with 72-hour regulatory countdown

- Data Subject Request (DSR) management and deadlines
- Consent and legal basis tracking per processing activity
- Retention policies and automated schedule enforcement
- International data transfer tracking
- Privacy notices and data controller management
- Legitimate Interest Assessments (LIAs)
- Security measures catalogue
- 27 jurisdictions: GDPR, UK GDPR, LGPD, CCPA, CDPA and more
- AI-assisted DPIA, RoPA and breach analysis

Events emitted: `sentinel.breach.confirmed` `sentinel.breach.resolved` `sentinel.dpia.completed` `sentinel.dsr.overdue` `vendor.created`

Database tables: `sentinel_ropa` `sentinel_dpias` `sentinel_breaches` `sentinel_dsr` `sentinel_consent` `sentinel_retention` `sentinel_transfers` `sentinel_lias` `sentinel_security_measures` `sentinel_vendors` `sentinel_jurisdiction_config` `sentinel_controllers`

ERM — Enterprise Risk Management

Enterprise risk register, risk appetite, obligations and cross-module aggregation

Features

- Enterprise risk register aggregating all modules
- Risk appetite threshold definition and breach monitoring
- Risk library and category management
- Regulatory obligation tracking (jurisdiction-aware)
- Risk assessment workflow with treatment tracking
- Auto-receives risks escalated from ARIA, BCM, ORM and Sentinel

Events emitted: `erm.risk.identified` `erm.risk.escalated` `erm.risk.mitigated` `erm.risk.closed` `erm.appetite.breached`

Database tables: `erm_enterprise_risks` `erm_risk_appetite` `erm_risk_library` `erm_regulatory_obligations` `erm_assessments` `risk_register` (shared)

ORM — Operational Risk Management

Operational event logging, KRI tracking, RCSA and SLA compliance

Features

- Operational event logging with severity classification
- Key Risk Indicator (KRI) definition and threshold monitoring
- KRI auto-increment when configured event type fires
- KRI history tracking over time
- Risk and Control Self-Assessment (RCSA) workflow
- SLA tracking and compliance reporting

Events emitted: `orm.event.logged` `orm.event.elevated` `orm.event.resolved`

Database tables: `orm_events` `orm_kris` `orm_kri_history` `orm_rcsa_assessments` `orm_rcsa_controls`
`orm_event_templates`

Database Architecture

ThemisIQ uses a single unified database with tables namespaced by module prefix. All modules share a common set of platform tables for users, sessions, audit logging, events and cross-module linking.

Shared Platform Tables

Table	Purpose	Modules
cross_module_links	Semantic relationships between entities across all modules (triggers, implements, mitigates, escalated_to, evidence_for, derived_from, audits, elevated_to)	ALL
events	Central event bus — stores every cross-module event with type, source module, entity ID, JSON payload, and processing status	ALL
canonical_vendors	Deduplicated vendor registry shared by GRID, BCM and Sentinel	GRID, BCM, SENTINEL
risk_register	Unified risk register aggregating risks from ARIA, BCM, ORM and ERM	ARIA, BCM, ERM, ORM
audit_log	Immutable audit trail of all user actions — user, action, resource type, resource ID, timestamp	PLATFORM
users	User accounts with hashed passwords and role assignment	PLATFORM
sessions	Secure httponly session tokens with expiry	PLATFORM
notifications	Per-user notification queue and preference settings	PLATFORM
settings	Platform-wide configuration key/value store	PLATFORM

Module Table Inventory

ARIA: aria_frameworks · aria_controls · aria_control_mappings · aria_policies · aria_risks · aria_documents · aria_evidence · aria_ask_index (FTS5)

GRID: grid_audits · grid_controls · grid_evidence_items · grid_evidence_files · grid_findings · grid_non_conformances · grid_vendors · grid_compliance_scores · grid_timeline · grid_reports · grid_reminders · grid_approval_requests

BCM: bcm_bia · bcm_risks · bcm_plans · bcm_incidents · bcm_incident_chat · bcm_incident_updates · bcm_exercises · bcm_training · bcm_vendors · bcm_dependencies · bcm_plan_reviews · bcm_documents

SENTINEL: sentinel_ropa · sentinel_dpias · sentinel_breaches · sentinel_dsr · sentinel_consent · sentinel_retention · sentinel_transfers · sentinel_lia · sentinel_security_measures · sentinel_vendors · sentinel_jurisdiction_config · sentinel_controllers

ERM: erm_enterprise_risks · erm_risk_appetite · erm_risk_library · erm_regulatory_obligations · erm_assessments · risk_register (shared)

ORM: orm_events · orm_kris · orm_kri_history · orm_rcsa_assessments · orm_rcsa_controls ·
orm_event_templates

Cross-Module Integration

When significant events occur in one module, they automatically trigger actions in related modules. Relationships between entities are recorded in the `cross_module_links` table.

Relationship Types

related · triggers · evidence_for · implements · mitigates · escalated_to · derived_from · audits · elevated_to

Automated Event Flows

Sentinel breach confirmed (SEV-1)

Source	Target	Effect
Sentinel	ERM	Creates jurisdiction-aware regulatory obligation + escalates to enterprise risk register
Sentinel	GRID	Creates post-incident audit titled "[Regulation] Breach Response Audit"
Sentinel	ORM	Logs operational event "[Regulation] Data Breach: [Title]"
Sentinel	ARIA	Flags related framework controls for review

BCM incident declared (SEV-1/SEV-2)

Source	Target	Effect
BCM	Sentinel	Auto-creates breach assessment draft if data may be involved
BCM	ARIA	Flags related controls as potentially impacted
BCM	ORM	Logs corresponding operational event

ARIA policy published

Source	Target	Effect
ARIA	GRID	Flags related audit controls for re-review
ARIA	Sentinel	Flags affected DPIAs for re-assessment
ARIA	BCM	Updates linked BCP plan review status

GRID audit non-conformance raised

Source	Target	Effect
GRID	ARIA	Creates corrective action on related control

GRID	BCM	Flags finding if it impacts continuity plans
-------------	------------	--

ORM KRI threshold breached

Source	Target	Effect
ORM	ERM	Elevates to enterprise risk register via elevated_to link

How the System Works

A practical walkthrough of how a compliance team uses ThemisIQ day-to-day, from initial setup through to incident response.

Step 1 — Set up frameworks in ARIA

Import the frameworks your organisation must comply with — ISO 27001, GDPR, SOC 2, NIST CSF, etc. ARIA imports the full control set and cross-maps controls that satisfy multiple frameworks simultaneously. Assign owners and track compliance status across all frameworks in one view.

Step 2 — Configure your jurisdiction in Sentinel

Tell Sentinel which data protection regulation(s) apply (GDPR, UK GDPR, LGPD, CCPA, etc.). This configures breach notification deadlines, DSR response windows, regulatory authority names, and notification language automatically. Then create your Records of Processing Activities (RoPA).

Step 3 — Schedule and run audits in GRID

Create audit programmes against ARIA frameworks. GRID samples controls for testing; you collect evidence and record findings. Non-conformances (NCs) link back to the relevant ARIA control and trigger corrective action workflows. GRID generates branded PDF/DOCX audit reports on demand.

Step 4 — Build continuity plans in BCM

Conduct Business Impact Analyses to identify critical processes and recovery time objectives. Build continuity plans, map vendor and system dependencies, and run tabletop exercises to test readiness. During a real incident, BCM's live chat console coordinates the response team in real time.

Step 5 — Log and monitor operational events in ORM

Define Key Risk Indicators (KRIs) with thresholds — for example, more than 3 access control failures in a week. As operational events are logged, KRIs with matching event types auto-increment. When a KRI threshold is breached, ORM escalates it to ERM automatically.

Step 6 — Monitor enterprise risk in ERM

ERM is the central aggregation point. Risks escalated from ARIA, BCM, ORM and Sentinel all appear in one enterprise risk register. Define risk appetite thresholds by category; ERM alerts when aggregate risk exceeds appetite.

Step 7 — Respond to a data breach (full cross-module flow)

When a breach is confirmed in Sentinel, the platform automatically: (1) starts the regulatory countdown timer, (2) creates a post-incident audit in GRID, (3) logs the breach as an operational event in ORM, (4) creates a regulatory obligation row in ERM, and (5) flags affected ARIA controls for review — all linked via `cross_module_links`.

***i** Ask ARIA — at any point in the workflow, use ARIA's semantic search to ask natural-language questions about your policies and controls: "What controls cover access management?" or "Which policies apply to data retention?"*

Security & Audit

Every action on the platform is logged. Access is controlled by role-based permissions with atomic capabilities.

Authentication

Secure httponly session cookies with SameSite=Strict. Session tokens are cryptographically random, stored in the sessions table with expiry. Passwords hashed with bcrypt cost-12.

Role-Based Access Control

14 platform roles, each granting a set of atomic capability permissions. Access to every endpoint is checked against the user's capabilities, not just their role name.

Immutable Audit Log

Every state-changing action is appended to the audit_log table — user, action, resource type, resource ID, and timestamp. Entries are never deleted.

SQL Injection Prevention

All database queries use parameterised statements. No string interpolation of user input into SQL is permitted anywhere in the codebase.

User Roles

ThemisIQ defines 14 roles covering platform administration through read-only external access.

Role	Access Scope	Typical User
Super Admin	Full platform access including user management and settings	Platform owner / IT administrator
Compliance Manager	All six modules, read-write across all compliance data	Head of compliance
ARIA Manager	Full access to ARIA frameworks, controls, policies and risks	GRC analyst
Audit Manager	Full access to GRID audits, evidence, NCs and reports	Internal / external auditor lead
Auditor	GRID evidence capture and finding creation; read-only elsewhere	Auditor team member
BCM Manager	Full BCM module access — plans, incidents, exercises	Business continuity officer
DPO	Full Sentinel access — RoPA, DPIA, breaches, DSR	Data Protection Officer
Privacy Analyst	Sentinel read-write except jurisdiction config	Privacy team member
Risk Manager	ERM and ORM full access; cross-module risk visibility	Enterprise risk officer
Department Head	Own module read-write; read-only on others	Divisional manager
Employee	Submit events, view own tasks and notifications	General staff
External Auditor	Read-only GRID evidence and reports (via share link)	Third-party auditor
Vendor	View and respond to vendor assessments only	Third-party supplier
Read Only	View all modules, no write access	Executive / observer